

CONFIDENTIAL - REMEDIATION EVIDENCE

VAPT Remediation & Retest Report

TATA Advanced Systems Limited (TASL)

ALS50 Service Management Portal

ASSESSMENT BASELINE
08 September 2026

REPORT VERSION
1.0

RETEST EXECUTION
05 October 2026

CLASSIFICATION
Confidential

Document Control & Executive Outcome

FIELD	VALUE
Client	TATA Advanced Systems Limited
Application	ALS50 Service Management Portal
Prepared by	TechRubix LLP Security Team
Assessment baseline	08-Sep-2026
Remediation/retest date	05-Oct-2026
Evidence type	Current code, configuration, production dependency audit, targeted API security tests and frontend build.

Executive Outcome

The confirmed critical/high findings from the baseline assessment have been remediated in the current workspace and retested at source/build level. The production dependency audit now reports zero critical and zero high advisories. The HTTPS configuration has been hardened in source; runtime gateway validation remains pending because the local Docker engine and approved TLS deployment target were unavailable.

3 REMEDIATED FINDINGS	1 DEPLOYMENT RETEST PENDING	0 CRITICAL ADVISORIES	0 HIGH ADVISORIES
---	---	---	---

Current risk statement: The baseline Critical API exposure is closed by source and regression-test evidence. Overall residual risk is **Medium** pending deployed HTTPS validation, authenticated multi-role authorization testing, and treatment of two moderate transitive dependency advisories.

Finding Closure Summary

FINDING	BASELINE SEVERITY	STATUS	RETEST RESULT	EVIDENCE
SEC-001 Generic records API access control	Critical	REMEDIA TED	PASS: anonymous requests return 401	EVD-R01, EVD-R02
SEC-002 jspdf dependency advisory	Critical	REMEDIA TED	PASS: zero critical production advisories	EVD-R03, EVD-R04
SEC-003 xlsx and Tiptap advisories	High	REMEDIA TED	PASS: xlsx removed, zero high production advisories	EVD-R03, EVD-R04, EVD-R05
SEC-004 HTTPS response headers	Medium	IMPLEME NTED	PARTIALLY REMEDIATED: source updated, gateway test pending	EVD-R06, EVD-R07

Scope qualification: No production API, public gateway, TLS endpoint, database, or customer data was accessed. A source/build retest proves implementation and local behavior only. Deployed infrastructure behavior remains Evidence Pending until an authorized target is available.

SEC-001 Remediation Evidence

Implemented Controls

Generic records reads now require an authenticated session. Generic record mutations require an Administrator session and a valid CSRF token for cookie-authenticated requests. The previously unprotected component-lifecycle repair attachment write operation now requires an authenticated session and CSRF validation.

```
backend/app/api/v1/records.py
from app.api.v1.authentication import require_administrator, require_csrf, require_session

@router.get("/{resource}")
def list_records(..., claims: dict = Depends(require_session), database: Session = Depends(get_db)):
    ...

@router.put("/{resource}")
def replace_records(..., _: None = Depends(require_administrator), csrf: None = Depends(require_csrf), database: Session = Depends(get_db)):
    ...

@router.post("/{resource}/bulk-upsert")
def bulk_upsert_records(..., _: None = Depends(require_administrator), csrf: None = Depends(require_csrf), database: Session = Depends(get_db)):
    ...
```

Regression-Test Evidence

```
Command: python -m pytest tests\test_records_api_security.py -q
Result: 3 passed

Covered cases:
GET /api/v1/records/incidents without a session returns 401.
PUT/POST generic record mutations without a session return 401.
POST /api/v1/component-lifecycle/repairs/attach without a session returns 401.
```

Remaining retest: Use approved administrator, ordinary-user, group-member and approver accounts to verify 401 anonymous, 403 unauthorized, CSRF enforcement, and permitted administrator paths across every resource and mutation type.

SEC-002 and SEC-003 Dependency Evidence

COMPONENT	BASELINE	CURRENT REMEDIATION	STATUS
jspdf	2.5.2 direct critical advisory	Updated to 4.2.1	REMEDIED
Tiptap packages	3.29.2 chain high advisory	Updated as a compatible set to 3.31.4	REMEDIED
xlsx	0.18.5 direct high advisory	Removed from package and source; workflows migrated to ExcelJS with a 10 MB import limit	REMEDIED

Production Dependency Audit

```
Command: npm audit --omit=dev --json
Current result: critical=0, high=0, moderate=2, low=0, total=2.
Remaining moderate advisories: exceljs (direct) and transitive uuid.
Npm reports a fix only through a breaking ExcelJS downgrade. No forced downgrade was applied.
```

Spreadsheet Control Evidence

```
frontend/src/data/spreadsheet.js
const MAX_WORKBOOK_BYTES = 10 * 1024 * 1024

export async function readWorkbook(arrayBuffer) {
  if (arrayBuffer.byteLength > MAX_WORKBOOK_BYTES) throw new Error('Workbook exceeds the 10 MB import limit.')
  const workbook = new ExcelJS.Workbook()
  await workbook.xlsx.load(arrayBuffer)
}
```

Build Evidence

```
Command: npm run build
Result: PASS - Vite production build completed successfully.
Additional source check: no xlsx import remains under frontend/src.
```

SEC-004 HTTPS Hardening Evidence

The HTTPS Nginx profile now includes the same response-header baseline as the standard profile and adds HSTS for the TLS deployment path.

```
frontend/nginx.https.conf
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
add_header X-Content-Type-Options "nosniff" always;
add_header X-Frame-Options "DENY" always;
add_header X-XSS-Protection "1; mode=block" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
add_header Permissions-Policy "geolocation=(), microphone=(), camera=(), payment=(), usb=(), magnetometer=(),
gyroscope=(), accelerometer=()" always;
add_header Content-Security-Policy "default-src 'self'; ...; frame-ancestors 'self'" always;
```

Retest Status

VERIFICATION	STATUS	EVIDENCE / LIMITATION
Source configuration comparison	PASS	HTTPS profile includes required baseline directives.
Compose validation	PENDING	Requires configured TLS_CERT_PATH and TLS_KEY_PATH values.
Nginx syntax test	PENDING	Docker Desktop engine unavailable locally.
Deployed header capture	EVIDENCE PENDING	Requires approved HTTPS endpoint and redacted application/API/error response captures.

Required deployment retest: Validate HSTS, CSP, nosniff, frame policy, referrer policy and permissions policy at the deployed HTTPS gateway. Confirm that HSTS scope is compatible with all subdomains before production approval.

Evidence Register, Residual Risk & Sign-Off

ID	TYPE	FINDING	DESCRIPTION
EVD-R01	Source review	SEC-001	Authentication, administrator and CSRF dependencies added to generic record operations and lifecycle attach write.
EVD-R02	Regression test	SEC-001	Targeted pytest suite: 3 passed unauthenticated access-control cases.
EVD-R03	Manifest/lockfile review	SEC-002/003	jspdf and Tiptap upgrades; xlsx removal; ExcelJS spreadsheet adapter added.
EVD-R04	Dependency audit	SEC-002/003	Production audit after remediation: 0 critical, 0 high, 2 moderate.
EVD-R05	Build/source scan	SEC-003	Vite build passed; no xlsx import remains under frontend source.
EVD-R06	Configuration review	SEC-004	HTTPS Nginx header baseline and HSTS directives added.
EVD-R07	Deployment limitation	SEC-004	Runtime parser and gateway validation pending approved TLS values and active Docker/deployment environment.

Residual risks: two moderate ExcelJS/uuid advisories remain; production HTTPS response validation and authenticated role-matrix testing are pending. These items require tracking to closure or acceptance by the named risk owner with an expiry date.

Formal Sign-Off

ROLE	NAME	SIGNATURE	DATE
TechRubix LLP Security Team			
TASL Application Owner			
TASL Engineering / DevOps Owner			
TASL Security Reviewer			
TASL Risk Owner			
TASL Approval Authority			

Sign-off acknowledges the remediation evidence, outstanding deployment retest, and residual-risk register. It does not certify that untested controls are secure.

Final Management Sign-Off

This final page records management acknowledgment of the remediation evidence, the residual-risk register, and the mandatory deployment retest before production closure.

DECISION	RECORD
SEC-001, SEC-002 and SEC-003	Source/build-level remediation verified. Production release remains subject to normal change approval.
SEC-004	Configuration remediation implemented. Gateway header capture and Nginx/TLS deployment validation remain required.
Residual risk	Two moderate ExcelJS/uuid advisories and all untested infrastructure controls require tracked risk ownership or subsequent remediation.

Formal Sign-Off

ROLE	NAME	SIGNATURE	DATE
TechRubix LLP Security Team			
TASL Application Owner			
TASL Engineering / DevOps Owner			
TASL Security Reviewer			
TASL Risk Owner			
TASL Approval Authority			

Approval condition: Final production closure requires retained evidence of deployed HTTPS response headers, an authorized role-matrix API retest, and a documented decision for the remaining moderate dependency advisories.